AML/CFT Exam Prep
Complete Study Guide

Screenshot Questions + Hard PDF

Agenda

1. AFC Regs
2. DNFBPs
3. Nonbank Financial
4. Guidance
5. Hard Questions

What: EU reg Jan 2025 — Applies to FIs + ICT providers — Purpose: withstand, recover from ICT disruptions
Why Advanced Testing:

Traditional	**DORA Advanced**
Checks compliance with known standards	Simulates real cyber attacks
Passive checking	Active threat-led testing

Key Tests: Basic (vuln scans) → Advanced (pen testing) → TLPT (mandatory 3yrs)

[SCENARIO]

Bank passes compliance but fails against ransomware.

[TRAP]

Not "Because regulators require it." Purpose = detect vulnerabilities BEFORE incidents.

[CORRECT]

To detect potential vulnerabilities and assess system defences before incidents occur.

UK Bribery Act 2010	US FCPA
Prohibits facilitation payments	**Allows** facilitation payments
No exception for local law	Exception if required by local law
Covers **both** giving AND receiving	Primarily covers giving (payer side)
Wide extra-territorial reach	Extra-territorial but narrower

Facilitation: FCPA permits small, routine; UK Act **Completely prohibited**

[TRAP]

"UK Act only UK-based" – WRONG. Applies to ANY with close connection to UK.

[CORRECT]

UK Bribery Act 2010 prohibits facilitation payments made to officials.

Scenario: Low risk customer now flagged in sanctions + adverse media.
Required:

Step 1	**Immediate Freeze** if sanctions match
Step 2	**Escalate** to MLRO immediately
Step 3	**EDD** – Enhanced Due Diligence
Step 4	**Risk Reassessment** – NO LONGER low risk
Step 5	**SAR Consideration**

[TRAP]

Not "monitor" – sanctions match requires IMMEDIATE ACTION.

Three Main Problems:

1. **Fragmented Supervision:** Multiple regulators, overlapping reqs, no single oversight
2. **Lack of Co-operation:** Slow info sharing, different privacy regimes
3. **Gaps in Transposition:** EU Directives implemented differently, regulatory arbitrage

[SCENARIO]

Criminal moves money Germany $\longrightarrow$ Malta $\longrightarrow$ UK. Different frameworks.

[TRAP]

NOT "technology" – it's regulatory, legal, co-operation gaps.

[CORRECT]

Fragmented supervision, lack of cooperation, gaps in transposition.

6AMLD: Expanded predicate offenses — Aiding/abetting liability — Min 4 yrs imprisonment
AMLR – New Entities:

Traditional	Newly Included
Lawyers	**Cryptoasset Service Providers (CASPs)**
Notaries	**Soccer Agents**
Accountants	Virtual Currency Exchanges

Why Soccer Agents? High-value intl transfers, large fees (10-30%), recent ML cases.

[TRAP]

Includes BOTH CASPs AND Soccer Agents – not just one!

[CORRECT]

Cryptoasset service providers and Soccer agents.

PEP Indirect Ownership

Scenario: PEP using indirect ownership intermediaries.
Why GREATEST Concern:

1. **Obfuscation:** PEPs high-risk; intermediaries hide true ownership
2. **Increased Risk:** PEP + offshore = high ML/TF
3. **CDD Breakdown:** Standard CDD won't reveal PEP
4. **Regulatory Risk:** Violates FATF Rec. 12

PEP Levels: Domestic (lower), Foreign (higher), International (highest)

[TRAP]

Concern NOT "buying expensive" – it's PEP using indirect ownership to hide.

[CORRECT]

PEP using indirect ownership intermediaries.

Two Effective:

1. **Strong Training:** Typologies, suspicious indicators, update annually
2. **Restrict Escrow:** Only if risk assessed; high-risk requires EDD; monitor unusual instructions

NOT Effective: "Confidentiality agreements to shield PEP" – INCREASES risk

[TRAP]

Confidentiality does NOT replace CDD – hiding PEP info INCREASES risk.

[CORRECT]

Strong training; Restricting escrow unless risk-assessed.

Scenario: Exporter ships **below** market; counterpart pays remainder via wire to third party. → **TBML**
TBML:

Under-Invoicing	**Over-Invoicing**
Invoice less than actual	Invoice more than actual
Goods $100k invoice $70k	Goods $100k invoice $150k
Difference separate channels	Difference separate account
Moves value **out**	Moves value **into**

[TRAP]

NOT "misclassification" – specifically over/under-invoicing.

[CORRECT]

Over/under-invoicing to obscure monetary transfers.

Three Required Actions:

1. **Monitor Volume:** Compare actual to stated purpose; predictable patterns
2. **Review Third-Party Use:** Official use ONLY; watch private individuals/businesses
3. **Clarify Sanctions:** Funds shouldn't go to sanctioned countries; consider STR

Why Higher Risk: Diplomatic immunity limits enforcement; large funds; sanctions evasion

[TRAP]

ALL THREE actions – volume, private use, AND sanctions screening!

[CORRECT]

Monitor volume; Review private use; Clarify sanctions.

FTZ Misclassification

Scenario: FTZ firm: **Incoming**=Pharma, **Outgoing**=Shoes. Same firm.
What: Trade-Based Misclassification – goods described as one thing, are another. Moving value, not goods.
Why FTZs High Risk:

1. Limited customs oversight
2. Goods move without full inspection
3. Tariffs reduced/eliminated
4. Attracts exploitation

[TRAP]

Specifically misclassification – not over/under-invoicing, not smuggling.

[CORRECT]

Trade-based misclassification masking value movement.

Three Critical Characteristics:

1. **Coverage All Major Blockchains:** BTC, ETH, USDT, USDC, BNB, XRP. Missing = blind spot
2. **Entity Resolution:** Link addresses to real-world; exchange data, OSINT, sanctions
3. **Broad Alerting:** Not just sanctions; suspicious patterns (layering, splitting, volume)

NOT Effective: "Real-time monitoring of internal performance metrics"

[TRAP]

Don't choose "internal performance metrics" – it's HOW you monitor, not what analytics DO.

[CORRECT]

Coverage all blockchains; Entity resolution; Broad alerting.

Two Most Relevant Risks:

1. **Limited Regulatory Oversight:** Weak/non-existent AML; FATF Grey/Black Lists
2. **Facilitating Fraudulent Transactions:** Fraudulent merchants; ML and fraud overlap

Additional: High volume low value, fast processing, cross-border, third-party agents

[TRAP]

Don't confuse with "terrorism" or "sanctions" – these are MOST RELEVANT for PSPs.

[CORRECT]

Limited oversight jurisdictions; Facilitating fraudulent transactions.

Scenario: Growing TM alerts for new crypto product.
DO:

1. **Review alert logic** – thresholds appropriate?
2. **Calibrate thresholds** – product-specific
3. **Investigate root cause** – attracting high-risk?
4. **Update EWRA** – new risk profile

DO NOT:

- Dismiss as "noise"
- Increase thresholds without analysis
- Ignore trend

[TRAP]

NOT "increase thresholds" – must investigate first.

Scenario: FIU paper says regional real estate product associated with fraud.
Correct Sequence:

1. **First: Understand Risk** – do you offer this product?
2. **Second: Update Risk Assessment** – incorporate new info
3. **Third: Consider Controls** – based on your specific risk
4. **Fourth: Implement Controls** – after assessment, proportional

Why NOT Suspend: Overreaction if low risk; loss of business; not risk-based

[TRAP]

ASSESS FIRST, then ACT. Immediate suspension = overreaction.

[CORRECT]

Assess internal risk exposure and update EWRA accordingly.

Three Key Impacts:

1. **Customer Experience:** More docs, longer onboarding, frequent reviews
2. **Control Redundancy:** Multiple duplicate controls, overlapping reporting
3. **Resource Impacts:** IT changes, training, more staff, higher costs

NOT an Impact: "Loss of audit rights" – regulators ALWAYS retain audit rights

[TRAP]

"Loss of audit rights" NOT an impact – regulators always have audit rights.

[CORRECT]

Customer experience; Control redundancy; Resource impacts.

EPD = Effective, Proportionate, Dissuasive

1. **Effective**: actually deters
2. **Proportionate**: fits severity
3. **Dissuasive**: discourages future

Sanctions: Criminal (imprisonment, fines), Civil (penalties, damages), Administrative (license, cease, debarment)
ALL THREE against BOTH individuals AND legal persons.

[SCENARIO]

$500 fine for $50M AML failure.

[TRAP]

Fine exists but is it DISSUASIVE? NO! $500 for $50M violates EPD.

[CORRECT]

Criminal, civil, AND administrative sanctions against both individuals and legal persons.

Key: Records **EXPEDITIOUSLY** – days, not months.

[SCENARIO]

$20M corruption case. Bank records take 6-9 months. Funds moved through 3 jurisdictions.

Rec. 30 vs. 31:

Rec. 30	**Rec. 31**
FIU and LE structure	Specific powers available to LE
Structural	Operational

SITs: Controlled delivery, surveillance, undercover, asset forfeiture.

[TRAP]

Long delays violate Rec. 31 specifically – not just Rec. 30.

[CORRECT]

Inability to obtain records expeditiously violates Rec. 31.

Critical: MUST provide guidance and feedback.
What: Red flags, typologies, STR feedback, best practices, outreach

[SCENARIO]

FIU receives 85k STRs, disseminates 12k, NEVER provides feedback.

[TRAP]

Don't confuse with Rec. 20 (STR filing) – violation is LACK OF FEEDBACK.

[CORRECT]

Rec. 34 – Guidance and feedback are REQUIRED, not optional.

UNSCR 1540, 1718, 1737, 2231, 2270
PF Red Flags:

1. **Dual-Use** to sanctioned (precision bearings 15k RPM, maraging steel)
2. **Inconsistent End-Use** ("agricultural" for missile components)
3. **Unusual Shipping** (multiple countries, FTZ transshipment)
4. **Payment Anomalies** (third-party intermediaries, shell companies)

[SCENARIO]

$3.2M precision bearings for "food processing" in UNSC-sanctioned country.

[TRAP]

NOT standard TBML – it's PROLIFERATION FINANCING.

[CORRECT]

Proliferation financing under UNSCR 1540 and FATF Rec. 7.

What: Country's ability to prevent/stop WMD proliferation financing
Areas:

1. Implementation of UNSCR 1540
2. Targeted financial sanctions for proliferators
3. Detection of dual-use exports
4. Coordination between customs, intelligence, financial authorities

Key: IO.11 is SEPARATE from ML/TF controls.

[SCENARIO]

Country Z has EXCELLENT ML/TF controls but has never identified PF case. Dual-use flows freely.

[TRAP]

Strong ML/TF $\neq$ strong PF – IO.11 is SEPARATE.

[CORRECT]

IO.11 – weak PF controls result in separate low rating.

TCSP = Trust and Company Service Providers
Six Activities Requiring CDD:

1. Formation agent for legal persons
2. Director or secretary
3. Registered office address
4. Nominee shareholder
5. Trustee of express trust
6. Nominee director

[SCENARIO]

Law firm forms 15 BVI companies for never-met client. Provides nominee directors and registered office. Client refuses ID/UBO.

[TRAP]

Attorney-client privilege does NOT exempt TCSP activities.

[CORRECT]

TCSP (formation + nominee + registered office). CDD required. Privilege does NOT apply.

AMLA: First centralized EU AML supervisor — Operational 2026 — Frankfurt HQ — Direct powers over highest-risk FIs
7AMLD Provisions:

1. **EUR 10,000 Cash Limit:** Mandatory across ALL EU; member states may set LOWER
2. **BO Registers:** Public access restored (legitimate interest test)
3. **VASP Travel Rule:** Enforcement strengthened

[SCENARIO]

EUR 450k real estate. Buyer offers EUR 350k cash, remainder bank transfer.

[TRAP]

Cash NOT permitted just because reported.

[CORRECT]

NO. EUR 350k cash exceeds EUR 10k limit.

CBDDQ = Correspondent Banking Due Diligence Questionnaire
Three Sections:

Section 1	AML/CFT Policies & Procedures
Section 2	Customer Base Risk (MSBs, NBFIs, foreign PEPs, shell cos)
Section 3	Independent Testing (audit schedule, scope, findings)

Most Critical: Unlicensed MSBs + no recent independent audit.

[TRAP]

CBDDQ does NOT ask about CEO personal investments or office locations.

[CORRECT]

Focuses exclusively on AML controls, customer base, independent testing.

Section 312 (PATRIOT Act): U.S. banks MUST apply EDD to correspondent accounts of foreign banks.
Triggers:

1. Offshore license (Cayman, BVI, Bahamas, Bermuda, Panama)
2. PEP customers as significant base
3. Grey List or Black List jurisdiction
4. Payable-through accounts
5. NOT a U.S. bank subsidiary

Required EDD: Determine payable-through; identify owners; enhanced scrutiny; verify AML controls

[TRAP]

Section 312 EDD is MANDATORY – not risk-based discretion.

[CORRECT]

EDD is mandatory – cannot "risk assess" your way out.

314(b): Information sharing among FIs.
Critical: Must file **OPT-IN** notice with FinCEN BEFORE sharing.
Requirements:

1. Opt-in with FinCEN (not automatic)
2. Confidentiality
3. Sharing limited to suspected ML/TF
4. May share SAR (exception to tipping-off)
5. Safe harbor from liability

Eligible: Banks, credit unions, broker-dealers, MSBs, casinos, insurance

[TRAP]

Sharing without opt-in is violation. Must file FIRST.

[CORRECT]

Must file opt-in notice with FinCEN before sharing.

4AMLD	5AMLD
EUR 250	EUR 150 (effective 2020)

Key:

- Prepaid ¿ EUR 150 must be linked to identified account
- Applies to all anonymous prepaid (including digital/virtual)
- Applies to single-use AND reloadable

[SCENARIO]

40 prepaid cards, each EUR 100 (total EUR 4,000). Each below 150.

[TRAP]

Each below 150 = no ID required PER CARD. But structural purchases may trigger structuring.

[CORRECT]

Maximum anonymous prepaid = EUR 150.

UNSCR 1373 vs. 1267

UNSCR 1267/1988	UNSCR 1373
Specific designated persons	General obligation to criminalize TF
UN Security Council maintains list	Countries create OWN designation lists
Mandatory freezing for all	Countries have discretion to designate
No country discretion to delist	Countries can establish own delisting

[SCENARIO]

Customer not on UN list. But domestic authority designated as terrorist financier.

[TRAP]

No UN listing = no obligation? WRONG.

[CORRECT]

YES – under UNSCR 1373, countries must freeze assets of DOMESTICALLY designated persons.

Original Four:

1. Internal controls
2. Designated compliance officer
3. Ongoing employee training
4. Independent testing

Fifth Pillar (2016 FinCEN CDD Rule):

5. **Customer Due Diligence (including Beneficial Ownership)**

CDD Rule:

- Identify/verify BO of legal entity customers
- Two-prong: Ownership (25%+) AND Control (at least one individual)
- Applies to LLCs, corps, partnerships, trusts

[TRAP]

BO identification is FIFTH pillar – NOT optional.

[CORRECT]

2016 CDD Rule (FinCEN) added BO as fifth pillar.

Line	Role
1st: Business	Own relationships, identify anomalies, collect CDD
2nd: Compliance	Oversight, monitoring, reporting, SAR filing
3rd: Audit	Independent assurance. Cannot design controls they test

Independence:

- Third line CANNOT design controls it tests
- Must be independent from ops AND compliance
- Reports to Board/Audit Committee

[SCENARIO]

Internal Audit designs AML monitoring AND tests it.

[TRAP]

This violates independence – not efficient.

[CORRECT]

Audit cannot design controls it later tests.

Art. 23: Member states may restrict data subject rights for AML/CFT.
Art. 48: Non-EU court judgments require MLAT or intl agreement.
Art. 49(1)(d): Allows transfers when "necessary for important public interest" – includes AML/CFT and law enforcement.

[SCENARIO]

U.S. grand jury subpoenas EU bank for customer records. No MLAT exists.

[TRAP]

GDPR prohibits all cross-border transfers without MLAT. WRONG.

[CORRECT]

Art. 49(1)(d) allows transfer if "necessary for important public interest" including AML/CFT.

OFAC 50% Rule

Principle:

- Ownership calculated by multiplying through tiers
- ONLY blocked entities transmit blocked status downstream

Example:

- X (SDN) owns 55% of A
- A owns 40% of B
- B owns 60% of C

Entity	Status
A	BLOCKED (55% ¿ 50%)
B	NOT BLOCKED (40% ¡ 50%)
C	NOT BLOCKED (B not blocked, so 60% does NOT transmit)

[TRAP]

C NOT blocked even though B owns 60%. Since B not blocked, cannot transmit.

[CORRECT]

C is NOT blocked. Only blocked entities transmit blocked status.

1. Fine $\neq$ dissuasive
2. Long delays = Rec. 31
3. Guidance = MANDATORY
4. Dual-use = proliferation
5. Weak PF = low IO.11
6. TCSP = CDD required
7. EUR 10k cash absolute
8. CBDDQ = AML only
9. Sec 312 = MANDATORY
10. 314(b) = OPT-IN
11. Anonymous prepaid = EUR 150
12. UNSCR 1373 = domestic
13. BO = 5th pillar
14. Audit CANNOT design
15. GDPR Art 49 exception
16. Only blocked transmits

GOOD LUCK!
All hard Domain B questions covered!